

# Richtlinie zur akzeptablen Nutzung von Unternehmenssystemen

Datum: [Heutiges Datum]

## Einleitung

Diese Richtlinie zur akzeptablen Nutzung von Unternehmenssystemen definiert die Anforderungen und Maßnahmen zur Sicherstellung einer sicheren und verantwortungsvollen Nutzung der IT-Ressourcen bei [Unternehmen]. Diese Richtlinie basiert auf den Standards ISO 27001:2022, ISO 27002:2022, CIS Controls v8, BSI C5:2020, der Cloud Controls Matrix (CCM), dem NIST Cybersecurity Framework 2.0, der NIS2-Richtlinie (EU 2022/2555), der OH SzA für KRITIS, dem European Cyber Resilience Act (CRA) und DORA.

## Geltungsbereich

Diese Richtlinie gilt für alle Mitarbeiter, Auftragnehmer, Berater, Zeitarbeitskräfte, Praktikanten und mit Dritten verbundene Personen, die Zugang zu den IT-Ressourcen von [Unternehmen] haben.

## Compliance Matrix

Die Compliance Matrix dient dazu, die Konformität dieser Richtlinie zur akzeptablen Nutzung von Unternehmenssystemen mit den relevanten Sicherheitsstandards und -richtlinien zu gewährleisten. Sie zeigt die Zuordnung der einzelnen Policy-Komponenten zu den spezifischen Anforderungen der Standards wie ISO 27001:2022, CIS Controls V8, BSI C5:2020, der Cloud Controls Matrix (CCM), dem NIST Cybersecurity Framework 2.0, der NIS2-Richtlinie (EU 2022/2555), der OH SzA für KRITIS, dem European Cyber Resilience Act (CRA) und DORA. Dies erleichtert die Nachverfolgung und Überprüfung, dass alle notwendigen Sicherheitsmaßnahmen implementiert sind und ermöglicht eine klare, transparente Dokumentation unserer Compliance-Verpflichtungen.

| Policy-Komponente            | ISO 27001:2022 / 27002:2022 | TISAX        | CIS Controls V8 | BSI C5:2020      | CCM            | NIST CSF 2.0       | NIS2 (EU 2022/2555) | OH SzA        | European CRA | DORA      |
|------------------------------|-----------------------------|--------------|-----------------|------------------|----------------|--------------------|---------------------|---------------|--------------|-----------|
| Allgemeine Nutzung           | 5.1, 5.2, 5.3               | 1.1.1, 1.2.1 | 6.1, 6.2, 6.3   | ORP1, ORP2, ORP3 | AIS-01, AIS-02 | GV.PO-01, PR.AA-01 | Artikel 21.2        | Abschnitt 2.3 | Artikel 10   | Artikel 5 |
| Persönliche Nutzung          | 5.10                        | 2.1.1, 2.1.2 | 5.1, 5.2        | ORP4, ORP5       | AIS-03         | GV.PO-01, PR.AT-01 | Artikel 21.2        | Abschnitt 2.4 | Anhang I     | Artikel 9 |
| E-Mail und Instant Messaging | 5.12                        | 3.1.1, 3.1.2 | 7.1, 7.2        | OPS1, OPS2       | DSI-01,        | PR.DS-01,          | Artikel 21.2        | Abschnitt 2.5 | Anhang I     | Artikel 9 |

| Policy-Komponente                        | ISO 27001:2022 / 27002:2022 | TISAX        | CIS Controls V8 | BSI C5:2020  | CCM            | NIST CSF 2.0       | NIS2 (EU 2022/2555) | OH SzA         | European CRA | DORA      |
|------------------------------------------|-----------------------------|--------------|-----------------|--------------|----------------|--------------------|---------------------|----------------|--------------|-----------|
|                                          |                             |              |                 |              | DSI-02         | PR.DS-02           |                     |                |              |           |
| Zugangskarten und Schlüssel              | 7.2                         | 3.2.1, 3.2.2 | 8.1, 8.2        | OPS3, OPS4   | IAM-01, IAM-02 | PR.AA-01, PR.AA-03 | Artikel 21.2        | Abschnitt 2.6  | -            | Artikel 9 |
| Verbotene Kommunikation                  | 5.19                        | 4.1.1, 4.1.2 | 9.1, 9.2        | ORP6, ORP7   | AIS-04, AIS-05 | GV.PO-02, PR.AT-02 | Artikel 21.2        | Abschnitt 2.7  | Anhang I     | Artikel 5 |
| Internetnutzung                          | 8.22                        | 4.2.1, 4.2.2 | 10.1, 10.2      | ORP8, ORP9   | IVS-01, IVS-02 | PR.PS-01, PR.PS-02 | Artikel 21.2        | Abschnitt 2.8  | Anhang I     | Artikel 9 |
| Nutzung von Arbeitsstationen und Laptops | 8.1, 8.2                    | 5.1.1, 5.1.2 | 11.1, 11.2      | PHY1, PHY2   | DSI-03, DSI-04 | PR.PS-01, PR.PS-05 | Artikel 21.2        | Abschnitt 2.9  | Anhang I     | Artikel 9 |
| Konsequenzen bei Richtlinienverstößen    | 5.22                        | 5.2.1, 5.2.2 | 12.1, 12.2      | ORP10, ORP11 | GOV-01, GOV-02 | GV.PO-02, GV.OC-03 | Artikel 21.2        | Abschnitt 2.10 | -            | Artikel 5 |
| Remote-Arbeit                            | 6.7, 6.8                    | 4.3.1, 4.3.2 | 13.1, 13.2      | ORP12, ORP13 | IAM-03, IAM-04 | PR.AA-04, PR.PS-01 | Artikel 21.2        | Abschnitt 2.11 | Anhang I     | Artikel 9 |
| Nutzung von Cloud-Diensten               | 5.23, 5.24                  | 4.4.1, 4.4.2 | 14.1, 14.2      | ORP14, ORP15 | CSP-01, CSP-02 | GV.SC-04, PR.DS-01 | Artikel 21.2        | Abschnitt 2.12 | Anhang I     | Artikel 9 |
| Zugriffskontrollen                       | 8.3, 8.4, 8.5               | 2.2.1, 2.2.2 | 15.1, 15.2      | ORP16, ORP17 | IAM-05, IAM-06 | PR.AA-01, PR.AA-03 | Artikel 21.2        | Abschnitt 2.13 | Anhang I     | Artikel 9 |

## Richtlinien und Anforderungen

### Allgemeine Nutzung

Die Nutzung der IT-Ressourcen muss in Übereinstimmung mit den Prinzipien der Vertraulichkeit, Integrität und Verfügbarkeit erfolgen (ISO 27001: 5.1, 5.2, 5.3). Alle Benutzer müssen sich der Richtlinien und Verfahren zur akzeptablen Nutzung bewusst sein und diese einhalten (CIS Controls 6.1, 6.2, 6.3, TISAX 1.1.1, 1.2.1). Es ist sicherzustellen, dass alle Aktivitäten protokolliert und überwacht werden, um

ungewöhnliche oder unautorisierte Aktivitäten frühzeitig zu erkennen (BSI C5: ORP1, ORP2, ORP3, CCM AIS-01, AIS-02).

### **Persönliche Nutzung**

Die persönliche Nutzung der IT-Ressourcen sollte minimal sein und die beruflichen Aufgaben nicht beeinträchtigen (ISO 27001: 5.10). Benutzer dürfen keine privaten Daten auf Unternehmensressourcen speichern oder nicht autorisierte Software installieren (CIS Controls 5.1, 5.2, TISAX 2.1.1, 2.1.2). Alle persönlichen Nutzungen müssen den Sicherheitsrichtlinien entsprechen und dürfen keine Risiken für die Unternehmenssicherheit darstellen (NIST CSF 2.0 GV.PO-01, PR.AT-01, European CRA Anhang I).

### **E-Mail und Instant Messaging**

E-Mails und Instant Messaging müssen für geschäftliche Zwecke verwendet werden und den Unternehmensrichtlinien entsprechen (ISO 27001: 5.12). Der Austausch vertraulicher Informationen über unsichere Kanäle ist untersagt (CIS Controls 7.1, 7.2, TISAX 3.1.1, 3.1.2). Benutzer müssen verdächtige E-Mails und Nachrichten umgehend dem IT-Sicherheitsteam melden (BSI C5: OPS1, OPS2, CCM DSI-01, DSI-02).

### **Zugangskarten und Schlüssel**

Der Zugang zu physischen und virtuellen Ressourcen muss strikt kontrolliert werden (ISO 27001: 7.2). Zugangskarten und Schlüssel dürfen nicht weitergegeben oder dupliziert werden (CIS Controls 8.1, 8.2, TISAX 3.2.1, 3.2.2). Verlorene oder gestohlene Zugangsmittel müssen sofort gemeldet werden (NIST CSF 2.0 PR.AA-01, PR.AA-03, NIS2 Artikel 21.2).

### **Verbotene Kommunikation**

Jegliche Kommunikation, die illegal ist oder gegen die Unternehmensrichtlinien verstößt, ist verboten (ISO 27001: 5.19). Dazu gehören diskriminierende, belästigende oder beleidigende Inhalte (CIS Controls 9.1, 9.2, TISAX 4.1.1, 4.1.2). Verstöße können zu disziplinarischen Maßnahmen führen (European CRA Anhang I, OH SZA Abschnitt 2.7).

### **Internetnutzung**

Der Zugriff auf das Internet muss sicher und kontrolliert erfolgen (ISO 27001: 8.22). Das Herunterladen und Installieren von nicht autorisierter Software ist untersagt (CIS Controls 10.1, 10.2, TISAX 4.2.1, 4.2.2). Alle Internetaktivitäten müssen den Sicherheitsrichtlinien entsprechen und dürfen keine Sicherheitsrisiken darstellen (NIST CSF 2.0 PR.PS-01, PR.PS-02, BSI C5: ORP8, ORP9, CCM IVS-01, IVS-02).

### **Nutzung von Arbeitsstationen und Laptops**

Arbeitsstationen und Laptops müssen sicher konfiguriert und vor unbefugtem Zugriff geschützt werden (ISO 27001: 8.1, 8.2). Dies beinhaltet die Implementierung von

Sicherheitsmaßnahmen wie Netzwerksicherheit, Zugriffskontrolle und Datensicherung (CIS Controls 11.1, 11.2, TISAX 5.1.1, 5.1.2). Regelmäßige Überprüfungen und Bewertungen der Systeme sind notwendig, um sicherzustellen, dass sie gegen aktuelle Bedrohungen geschützt sind (BSI C5: PHY1, PHY2, CCM DSI-03, DSI-04).

### **Konsequenzen bei Richtlinienverstößen**

Verstöße gegen diese Richtlinie können zu disziplinarischen Maßnahmen führen, die bis zur Beendigung des Arbeitsverhältnisses reichen können (ISO 27001: 5.22). Alle Vorfälle müssen dokumentiert und gemäß den Unternehmensrichtlinien gemeldet werden (CIS Controls 12.1, 12.2, TISAX 5.2.1, 5.2.2). Das Management ist dafür verantwortlich, geeignete Maßnahmen zu ergreifen, um Wiederholungen zu verhindern (NIST CSF 2.0 GV.PO-02, GV.OC-03, BSI C5: ORP10, ORP11, CCM GOV-01, GOV-02).

### **Remote-Arbeit**

Die Arbeit von entfernten Standorten muss sicher und kontrolliert erfolgen (ISO 27001: 6.7, 6.8). Sicherheitsmaßnahmen wie Netzwerksicherheit, Zugriffskontrolle und Datensicherung müssen implementiert werden, um die Integrität und Vertraulichkeit der Daten zu gewährleisten (CIS Controls 13.1, 13.2, TISAX 4.3.1, 4.3.2). Regelmäßige Überprüfungen und Bewertungen der Remote-Arbeitsplätze sind notwendig (NIST CSF 2.0 PR.AA-04, PR.PS-01, BSI C5: ORP12, ORP13, CCM IAM-03, IAM-04).

### **Nutzung von Cloud-Diensten**

Die Nutzung von Cloud-Diensten muss sicher und kontrolliert erfolgen (ISO 27001: 5.23, 5.24). Dies beinhaltet die Implementierung von Sicherheitsmaßnahmen wie Netzwerksicherheit, Zugriffskontrolle und Datensicherung (CIS Controls 14.1, 14.2, TISAX 4.4.1, 4.4.2). Regelmäßige Überprüfungen und Bewertungen der Cloud-Dienste sind notwendig, um sicherzustellen, dass sie gegen aktuelle Bedrohungen geschützt sind (NIST CSF 2.0 GV.SC-04, PR.DS-01, BSI C5: ORP14, ORP15, CCM CSP-01, CSP-02).

### **Zugriffskontrollen**

Zugriffskontrollen müssen implementiert werden, um den unbefugten Zugriff auf Unternehmensressourcen zu verhindern (ISO 27001: 8.3, 8.4, 8.5). Dies beinhaltet die Implementierung von Maßnahmen wie Authentifizierung, Autorisierung und Überwachung (CIS Controls 15.1, 15.2, TISAX 2.2.1, 2.2.2). Regelmäßige Überprüfungen und Bewertungen der Zugriffskontrollen sind notwendig (NIST CSF 2.0 PR.AA-01, PR.AA-03, BSI C5: ORP16, ORP17, CCM IAM-05, IAM-06).

### **Verantwortliche**

Die Implementierung und Einhaltung dieser Richtlinie liegt in der Verantwortung des IT-Sicherheitsbeauftragten und des Managements. Alle Mitarbeiter sind verpflichtet, sich an diese Richtlinie zu halten und jegliche Verstöße umgehend zu melden.

### **Quellen und Referenzen**

| Quelle                                    | Zweck                                                              | Link                                  |
|-------------------------------------------|--------------------------------------------------------------------|---------------------------------------|
| ISO27001:2022                             | Aufbau und Implementierung eines ISMS                              | <a href="#">ISO 27001:2022</a>        |
| CIS Controls v8                           | Sicherheitsmaßnahmen gegen Cyberangriffe                           | <a href="#">CIS Controls v8</a>       |
| BSI C5:2020                               | Cloud Security Standard                                            | <a href="#">BSI C5:2020</a>           |
| Cloud Controls Matrix (CCM)               | Sicherheitskontrollen für Cloud-Dienste                            | <a href="#">Cloud Controls Matrix</a> |
| NIST Cybersecurity Framework 2.0          | Rahmenwerk zur Verbesserung der Cybersicherheit                    | <a href="#">NIST CSF 2.0</a>          |
| NIS2-Richtlinie (EU 2022/2555)            | EU-Richtlinie zur Netz- und Informationssicherheit                 | <a href="#">NIS2</a>                  |
| OH SzA für KRITIS                         | Orientierungshilfe Angriffserkennung für Kritische Infrastrukturen | OH SzA                                |
| European Cyber Resilience Act (CRA)       | EU-Verordnung für sichere Produkte mit digitalen Elementen         | European CRA                          |
| Digital Operational Resilience Act (DORA) | EU-Verordnung zur digitalen operationellen Resilienz               | DORA                                  |

Diese Quellen und Referenzen bieten umfassende Leitlinien und Best Practices für die Entwicklung und Implementierung von Sicherheitsmaßnahmen sowie für die Einhaltung der relevanten Standards und Richtlinien. Sie dienen als Grundlage und Unterstützung bei der Implementierung und Aufrechterhaltung einer sicheren IT-Umgebung bei [Unternehmen].

---

## Dokumentinformationen

**Titel:** Richtlinie zur akzeptablen Nutzung von Unternehmenssystemen

**Version:** 1.0

**Datum:** [Heutiges Datum]

**Verantwortlich:** IT-Sicherheitsbeauftragter

**Genehmigt von:** [Name der genehmigenden Person]

**Nächste Überprüfung:** [Datum der nächsten Überprüfung]